

Aula 5 (Módulo 02) — Sysmon e PowerShell Logging

Esta é a aula de consolidação do Módulo 02. Vamos ver por que os logs nativos do Windows (Aula 4) muitas vezes **não são suficientes**, e quais duas ferramentas resolvem isso na prática.

1. O limite dos logs nativos

O Event ID 4688 (criação de processo, visto na aula anterior) é ótimo, mas tem limitações: por padrão, mesmo habilitado, ele pode não mostrar a **hash** do arquivo executado, não mostra conexões de rede feitas pelo processo, e não registra criação de arquivo. Para uma investigação completa, isso é uma lacuna grande — é aqui que entra o **Sysmon**.

2. Sysmon (System Monitor)

Sysmon é uma ferramenta **gratuita e oficial da Microsoft**, parte do pacote Sysinternals, que se instala como um serviço/driver no Windows e registra telemetria muito mais rica do que os logs padrão — em um log próprio:

Applications and Services Logs → Microsoft → Windows → Sysmon → Operational .

Principais Event IDs do Sysmon:

Event ID	Significado
1	Criação de processo (com hash do arquivo, command line completa, processo pai)
3	Conexão de rede (IP/porta de origem e destino, processo responsável)
7	Carregamento de imagem/DLL
11	Criação de arquivo
12/13/14	Criação, modificação ou renomeação de chave/valor do Registry
22	Consulta DNS feita por um processo

Por que importa para segurança: repare que o Sysmon cobre exatamente as lacunas que apontamos: o Event ID 1 já vem com **hash** (útil para checar contra Threat Intelligence — Módulo 12), o Event ID 3 mostra **qual processo** fez qual conexão de rede (algo que nem o `ss` / `lsof` do Linux, nem o log nativo do Windows, entregam junto de forma tão direta), e o 11/12/13/14 cobrem criação de arquivo e modificação de Registry — lembra das Run keys de persistência (Módulo 02, Aula 1)? O Sysmon é literalmente a ferramenta que **detecta a criação** dessas chaves em tempo real.

O Sysmon precisa de um **arquivo de configuração** (XML) que define exatamente o que registrar e o que ignorar (para não gerar volume excessivo de log) — configurações públicas e bem testadas, como a mantida pela comunidade em `SwiftOnSecurity/sysmon-config` , são um ponto de partida comum em ambientes reais. Vamos instalar e configurar o Sysmon de verdade no **Módulo 11**, dedicado só a ele.

3. PowerShell Logging

Vimos na Aula 2 deste módulo que PowerShell é uma ferramenta central de ataques modernos. Por padrão, o PowerShell **não registra tudo que é executado** — é preciso habilitar tipos específicos de logging:

Module Logging

Registra os comandos executados, mas de forma resumida.

Script Block Logging (o mais importante)

Registra o **conteúdo completo** de cada bloco de script executado — inclusive comandos que foram gerados dinamicamente ou ofuscados (como o `-enc` em Base64 que vimos na Aula 2): o PowerShell registra o script **já decodificado**, em texto legível, no Event ID **4104** do log `Microsoft-Windows-PowerShell/Operational`.

Transcription

Grava uma cópia em arquivo texto de toda a sessão do PowerShell, como se fosse uma gravação de tela em texto.

Por que importa para segurança: o Script Block Logging (Event ID 4104) resolve diretamente o problema da ofuscação Base64 que vimos na Aula 2 — em vez de você precisar decodificar manualmente o comando `-enc`, o próprio Windows já registra a versão decodificada no log. É considerado, por praticamente todo profissional de Blue Team, uma das configurações de logging de **maior custo-benefício** que existem: fácil de habilitar (via Group Policy), baixo volume comparado a outras fontes, e altíssimo valor de detecção.

4. Conectando os três pilares deste módulo

```
Event Log nativo (Aula 4)    → cobertura básica, sempre disponível,
                             mas limitado (sem hash, sem rede)
Sysmon (Event IDs 1,3,7,11...) → telemetria rica: processo+hash, rede,
                             arquivo, Registry
PowerShell Logging (4104)   → conteúdo real de scripts, mesmo ofuscados
```

Um SOC profissional normalmente usa os três juntos, todos enviados para um SIEM central (Módulo 09) — o que qualquer um deles perder, os outros dois costumam capturar.

5. Exercício de leitura (sem precisar instalar nada agora)

Reflita sobre este cenário, juntando tudo que vimos no módulo:

Um usuário recebe um e-mail com um anexo Word. Ele abre o arquivo e permite a execução de macro. A macro executa `powershell.exe -enc <base64>` para baixar e rodar um segundo estágio de malware, que se instala como uma tarefa agendada para persistência.

Tente responder, usando o que aprendemos neste módulo:

1. Qual Event ID nativo (Aula 4) mostraria a criação do processo PowerShell, e com qual processo pai?
2. Qual Event ID do Sysmon (esta aula) mostraria a **hash** desse PowerShell malicioso?
3. Qual Event ID de PowerShell Logging mostraria o **conteúdo real** decodificado do comando `-enc`?
4. Qual Event ID nativo (Aula 4) registraria a criação da tarefa agendada usada para persistência?

(Não vou entregar a resposta agora de propósito — tente responder sozinho com o que já vimos; se travar, é só me chamar que revisamos juntos.)

6. Recapitulando o Módulo 02

- Logs nativos (Security log, Event IDs 4624-4732) cobrem o essencial, mas com lacunas (sem hash, sem rede, sem Registry detalhado).
- **Sysmon** preenche essas lacunas: processo+hash (ID 1), rede (ID 3), arquivo (ID 11), Registry (ID 12/13/14).
- **PowerShell Script Block Logging** (Event ID 4104) neutraliza a ofuscação Base64, registrando o comando real decodificado.
- O padrão se repete: toda ferramenta administrativa poderosa (PowerShell, WMI, Task Scheduler, Registry) é ao mesmo tempo essencial para administração e um vetor de ataque comum — e cada uma tem uma forma específica de gerar evidência que aprendemos a reconhecer.

Módulo 02 concluído. 🎉

Próximo módulo

Módulo 03 — Redes (fundamento central): voltamos para a base teórica de IP, portas, TCP/UDP, DNS, HTTP/HTTPS — completando o que só arranhamos de leve no Módulo 01 (Aula 6, `ss / ip`) e que vamos aplicar em quase todo módulo daqui para frente (Network Security, SIEM, Threat Hunting, Web Security...).

Fontes recomendadas

- **Microsoft/Sysinternals — documentação oficial do Sysmon**: referência completa de configuração e Event IDs. <https://learn.microsoft.com/sysinternals/downloads/sysmon>
- **Microsoft Learn — "about_Logging_Windows"**: documentação oficial de Module Logging, Script Block Logging e Transcription no PowerShell. https://learn.microsoft.com/powershell/module/microsoft.powershell.core/about/about_logging_windows
- **MITRE ATT&CK — T1027 (Obfuscated Files or Information)**: técnica oficial associada ao uso de Base64/ofuscação, que o Script Block Logging ajuda a neutralizar. <https://attack.mitre.org/techniques/T1027/>